

Anonymisierte Betriebs- und Reproduktionsdokumentation

Segmentierte OPNsense-Infrastruktur als Arbeitsprobe

Joshua Pond

Stand: 27. April 2026

Hinweis zur Arbeitsprobe: Diese Dokumentation ist bewusst für ein Portfolio aufbereitet. Konkrete Hostnamen, interne IP-Adressen, Dateipfade, Providerbezeichnungen, Gerätekennungen und organisationsbezogene Details wurden generalisiert oder anonymisiert. Die technische Struktur, die Reihenfolge der Betriebsmaßnahmen und die fachliche Tiefe entsprechen dem realen Aufbau.

1 Ziel und Einordnung

Diese Arbeitsprobe dokumentiert den Betrieb und den reproduzierbaren Wiederaufbau einer segmentierten Firewall- und Proxy-Infrastruktur auf Basis von OPNsense. Der Schwerpunkt liegt nicht nur auf der reinen Inbetriebnahme einzelner Dienste, sondern auf dem Zusammenspiel aus Netzsegmentierung, sicherem Fernzugriff, Veröffentlichung von Diensten, Layer-7-Inspektion, Malware-Prüfung und dokumentierter Wiederherstellbarkeit.

Die Dokumentation verfolgt drei Ziele:

- den technischen Ist-Zustand nachvollziehbar zu beschreiben,
- die Wiederherstellung nach Störung oder Reset geordnet abbildbar zu machen,
- die fachliche Reichweite von Layer 2 bis Layer 7 transparent zu zeigen.

2 Technische Reichweite

Die folgende Übersicht macht sichtbar, dass sich die Arbeit nicht auf Basisdienste wie DHCP oder DNS beschränkt, sondern mehrere Ebenen des Infrastruktur- und Sicherheitsbetriebs umfasst.

Ebene	Themen im Aufbau	Typische Komponenten	Nachgewiesene Fähigkeiten
Layer 2	Trunk-/Access-Logik, Tagged/Untagged-Betrieb, PVID, VLAN-Zuweisung, Portrollen	Managed Switch, VLAN-Uplinks	saubere Segmentierung, nachvollziehbare Portplanung, Trennung von Management- und Client-Netzen
Layer 3	Interface-Adressierung, Inter-VLAN-Routing, VPN-Netze, DMZ-Trennung, DNS-/DHCP-Grundversorgung	OPNsense, WireGuard, Unbound, dnsmasq	Netzdesign, Gateway-Planung, Remote-Zugriff, Segmentkopplung mit klaren Rollen
Layer 4	Stateful Firewalling, Portfreigaben, PPPoE-Uplink, UDP-/TCP-Dienstpfade, Listener-Design	Firewall-Regeln, WAN-Uplink, Proxy-Ports, VPN-Port	Transportpfade verstehen, Dienste gezielt freigeben, Betriebs- und Fehlergrenzen sauber ziehen

Ebene	Themen im Aufbau	Typische Komponenten	Nachgewiesene Fähigkeiten
Layer 7	DPI, URL-/Kategorie-Kontrolle, TLS-Inspection, Reverse-Proxy-nahe Veröffentlichung, ICAP-Malware-Kette	Zenarmor, Squid, ICAP, c-icap, ClamAV	Applikationskontrolle, HTTP/HTTPS-Pfade verstehen, Inhaltsprüfung und sichtbare Blockmechanismen einordnen
Betrieb & Doku	stufenweiser Rollout, Abnahmekriterien, Backups, Recovery, Troubleshooting-Reihenfolge	Dokumentation, Hilfskripte, Sicherungen	strukturierte Arbeitsweise, reproduzierbare Änderungen, nachvollziehbare Übergabe und Fehlersuche

3 Architekturüberblick

Architekturprinzipien

Der Aufbau folgt einigen bewusst gewählten Betriebsprinzipien:

- **Management getrennt halten:** Das Management-Netz wird nicht mit experimentellen Proxy- oder DPI-Regeln belastet.
- **Segmentierung vor Komplexität:** Erst wenn Routing, DNS und DHCP stabil laufen, werden zusätzliche Sicherheits- und Proxy-Schichten aktiviert.
- **DMZ bleibt DMZ:** Veröffentlichte Dienste werden in einer eigenen Zone betrieben; die DMZ ist kein Ersatz für einen Administrationspfad.
- **Remote-Zugriff über VPN:** Administrativer Fernzugriff erfolgt über WireGuard statt über unsaubere Ausnahmen an der Perimeter-Zone.
- **Jede Ausbaustufe ist prüfbar:** Zwischen Konnektivität, Segmentierung, VPN und Sicherheitsstack liegen definierte Prüfpunkte.

Komponenten und Rollen

Komponente	Rolle im Aufbau
OPNsense-Firewall	zentrale Routing-, Security-, DHCP-, DNS-, VPN- und Proxy-Plattform
Managed Access Switch	Layer-2-Verteilung mit Trunk zum Firewall-Uplink sowie klaren Access-Port-Rollen
DMZ-Segment	separate Zone für veröffentlichte oder vorgeschaltete Dienste
WireGuard-VPN	sicherer Fernzugriff auf Management- und interne Netze ohne Aufweichung der DMZ
DPI-/Security-Schicht	Kategorisierung, Phishing-/Malware-Erkennung und zusätzliche Policy-Kontrolle
HTTP/HTTPS-Proxy-Schicht	sichtbare Website-Sperren, TLS-Inspection, Inhaltsweitergabe an ICAP/Antivirus

Anonymisierter Netz- und Zonenplan

Die folgenden Netze sind Portfolio-Beispielwerte. Sie zeigen die Struktur, nicht die echten Produktivadressen.

Zone	Beispielnetz	Rolle	Zweck
Management-LAN	10.20.0.0/24	untagged / Basis-netz	Administration, Basis-erreichbarkeit, Switch-Management
Client-VLAN A	10.20.10.0/24	tagged	Benutzer- oder WLAN-Segment
Client-VLAN B	10.20.20.0/24	tagged	separates internes Segment für Systeme oder Dienste
DMZ	10.20.30.0/24	eigene Zone	veröffentlichte oder vorgeschaltete Dienste
VPN	10.20.66.0/24	Tunnelnetz	administrativer Fernzugriff

4 Betriebsmodell

WAN und Edge-Anbindung

Der Internetzugang ist kein triviales DHCP-Szenario, sondern ein PPPoE-basierter Uplink mit vorgeschalteter VLAN-Kapselung. Das ist relevant, weil die Stabilität des Gesamtsystems nicht nur von den internen Netzen, sondern auch von einem sauberen WAN-Linkup abhängt.

Im realen Aufbau trat dabei ein provider- bzw. release-spezifischer Sonderfall auf: Die Einwahl war erfolgreich, die lokale Übergabe der IPv4 an das WAN-Interface jedoch nicht immer konsistent. Dieser Fehler war nur durch gezielte Prüfung der tatsächlichen Routing- und Linkup-Zustände erkennbar. Für den Betrieb bedeutet das:

- erfolgreiche Authentisierung ist noch kein Beweis für funktionierenden Internetzugang,
- WAN-Initialisierung muss immer gegen Route, Interface-Zustand und echten Datenverkehr validiert werden,
- Workarounds gehören dokumentiert und müssen nach Upgrades erneut geprüft werden.

Interne Netze, DHCP und DNS

Die Grundversorgung der internen Zonen erfolgt über die Firewall selbst. DHCP und DNS bleiben damit nahe an der Routing- und Sicherheitslogik, was Fehlersuche und Segmentverständnis deutlich vereinfacht.

Praktisch folgt der Aufbau einer klaren Reihenfolge:

1. Interface und Gateway pro Zone definieren.
2. DHCP-Bereiche je Segment aktivieren.
3. DNS-Resolver auf allen relevanten Interface-Adressen bereitstellen.
4. Pro Segment prüfen, ob Lease, Gateway, DNS-Auflösung und Internetzugang konsistent funktionieren.

Diese Basisschicht ist bewusst konservativ. Erst wenn sie stabil arbeitet, werden zusätzliche Dienste wie transparentes Proxying oder TLS-Inspection aktiviert.

Layer-2-Switching und VLAN-Verteilung

Der Switch übernimmt im Aufbau bewusst keine komplexe Sonderlogik, sondern eine klar lesbare Layer-2-Rolle:

- ein Trunk-/Hybrid-Port zur Firewall,
- ein untagged Management-Pfad,
- getrennte Access-Ports für die jeweiligen VLANs,
- möglichst wenig versteckte Zusatzfunktionalität.

Das reduziert Fehlerquellen. Vor allem in Störungssituationen ist eine einfache Portlogik wertvoller als ein vermeintlich „intelligenter“ Switch mit schwer nachvollziehbarem Eigenverhalten.

VPN und Fernadministration

Der Fernzugriff erfolgt über WireGuard in einem dedizierten Tunnelnetz. Die ausgelieferten Peer-Konfigurationen arbeiten bewusst als Split Tunnel:

- interne Netze bleiben sicher erreichbar,
- die Firewall selbst bleibt administrierbar,
- der komplette Internetverkehr externer Clients wird nicht unnötig durch die Firewall umgeleitet,
- Fehlersuche auf Mobil- und Client-Geräten bleibt überschaubar.

Aus Betriebssicht ist das ein kontrollierter und belastbarer Kompromiss aus Sicherheit, Administrierbarkeit und Nebenwirkungsfreiheit.

DMZ und veröffentlichte Dienste

Die DMZ ist als eigene Sicherheitszone ausgelegt. Ihr Zweck ist die Trennung öffentlich relevanter Dienste vom Management- und Client-Betrieb. Entscheidend ist dabei:

- veröffentlichte Dienste liegen nicht im internen Client-Netz,
- die DMZ ist kein dauerhafter Administrationspfad,
- Regeln zwischen DMZ und internen RFC1918-Netzen bleiben restriktiv,
- ein Reverse-Proxy- oder Veröffentlichungsdienst kann kontrolliert über WAN-Portweiterleitungen angebunden werden.

Security- und Proxy-Kette

Die Sicherheitskette ist mehrstufig und trennt bewusst zwischen Paketfilterung, Reputationskontrolle, DPI, sichtbarer Website-Sperre und Malware-Prüfung.

Stufe 1: Reputations- und Basisschutz CrowdSec entlastet klassische Firewall-Regeln durch reputationsbasierte Entscheidungen. Das ist kein Ersatz für Regelwerke, sondern eine zusätzliche Schutzschicht gegen auffällige oder bereits bekannte Quellen.

Stufe 2: Layer-7-Analyse und Kategorisierung Zenarmor bildet im Aufbau die DPI-/Policy-Komponente. Es liefert Sicht auf Anwendungen, Sitzungen und riskante Webkategorien. Wichtig ist hier die saubere Trennung:

- Management-Zonen werden nicht mit experimentellen Hooks belastet,
- inspiziert werden gezielt die Client-VLANs,
- Anti-Phishing- oder Malware-Kategorien sind eine andere Ebene als die sichtbare Proxy-Blockseite.

Stufe 3: Sichtbare HTTP/HTTPS-Kontrolle Squid übernimmt die Rolle des sichtbaren Blockpfads. Er stellt nicht nur Proxy-Funktionalität bereit, sondern ist für die kontrollierte Auslieferung eigener Sperr- oder Fehlerseiten zuständig. Dazu gehören:

- transparente HTTP- und HTTPS-Pfade,
- No-Bump-Ausnahmen für sensible Dienste oder Pinning-Szenarien,
- Blacklists, ACLs und benutzerdefinierte Fehlerseiten.

Stufe 4: Inhaltsprüfung Hinter dem Proxy arbeitet eine ICAP-basierte Kette mit `c-icap` und `ClamAV`. Damit ergibt sich für Downloads und relevante Objekte folgender Pfad:

Client -> Firewall -> Proxy/TLS-Inspection -> ICAP -> Antivirus

Diese Trennung ist für den Betrieb wichtig: Nicht jede Blockentscheidung kommt aus derselben Schicht. Für sauberes Troubleshooting muss immer klar sein, ob ein Problem im Routing, im Proxy, in der DPI-Policy, in der No-Bump-Liste oder in der Malware-Kette entsteht.

5 Reproduktionsleitfaden

Der Wiederaufbau folgt bewusst dem Prinzip **erst Basis, dann Segmentierung, dann Sicherheitsstack**. Komplexität wird nicht gleichzeitig, sondern stufenweise aktiviert.

1. Basissystem

1. OPNsense-Grundsystem bereitstellen.
2. physische Interfaces den Rollen LAN, WAN und DMZ zuordnen.
3. Management-LAN und DMZ mit den vorgesehenen Basisadressen versehen.
4. WebGUI und SSH aktivieren.

Abnahmekriterium: Lokale Administration, stabiler Lease im Management-LAN und konsistente Erreichbarkeit der Firewall.

2. WAN-Uplink

1. WAN-VLAN anlegen.
2. PPPoE konfigurieren.
3. Interface-Zustand, WAN-IP und Default-Route prüfen.
4. bei Bedarf den dokumentierten Workaround für den Linkup-Sonderfall anwenden.

Abnahmekriterium: Stabiler Internetzugang aus dem Management-LAN mit funktionierender Route und belastbarer Namensauflösung.

3. Interne Segmentierung

1. VLAN-Interfaces auf der Firewall anlegen.
2. Gateways, DHCP-Bereiche und DNS pro Segment aktivieren.
3. Switch-Portrollen für Trunk, Access und Management sauber setzen.

Abnahmekriterium: Je Segment funktionieren Lease, Gateway, DNS und Internetzugang reproduzierbar.

4. VPN und DMZ

1. WireGuard aktivieren und Tunnelnetz zuweisen.
2. WAN-Regel für den VPN-Dienst setzen.
3. DMZ-Regeln restriktiv halten und Administrationsausnahmen vermeiden.

Abnahmekriterium: Fernzugriff auf interne Netze funktioniert, ohne die DMZ als Notfall-Adminpfad zu missbrauchen.

5. Sicherheitsstack

Der Sicherheitsstack wird stufenweise aktiviert:

1. CrowdSec,
2. DPI-/Policy-Schicht,
3. expliziter Proxy,
4. transparentes HTTP,
5. transparentes HTTPS mit TLS-Inspection,
6. ICAP-/Antivirus-Kette.

Abnahmekriterium: Jede Schicht ist einzeln überprüfbar, rückrollbar und gegen die definierte Erwartung testbar.

6 Validierung und Betriebschecks

Nach Änderungen oder nach einem Wiederaufbau sollte mindestens der folgende Kurzcheck durchgeführt werden:

Prüfung	Erwartung
WebGUI und SSH im Management-Netz	Firewall ist lokal administrierbar und stabil erreichbar
DHCP je Segment	Clients erhalten passende Adressen aus dem richtigen Netz

Prüfung	Erwartung
DNS je Segment	Namensauflösung funktioniert über die lokale Firewall-Adresse des jeweiligen Netzes
Interner und externer Traffic	Routing und Internetzugang funktionieren konsistent
WireGuard	Handshake erfolgreich, Zugriff auf interne Netze möglich
DMZ / veröffentlichte Dienste	gewünschte Erreichbarkeit vorhanden, ohne unnötige Querverbindungen
Proxy / TLS-Inspection	explizite und transparente Pfade funktionieren wie geplant
Malware-Kette	Test nur mit kontrollierten Artefakten, z.B. EICAR, nicht mit echtem Schadcode

7 Warum diese Dokumentation betrieblich funktioniert

Eine gute technische Dokumentation ist im Betrieb nicht einfach nur „viel Text“. Sie muss vor allem:

- die Architektur klar in Rollen und Zonen beschreiben,
- Wiederaufbau und Fehlersuche in einer sinnvollen Reihenfolge führen,
- Ausnahmen, Risiken und Sonderfälle sichtbar machen,
- erklären, welcher Baustein wofür verantwortlich ist,
- auch Wochen später noch als Arbeitsgrundlage funktionieren.

Genau deshalb trennt diese Arbeitsprobe strikt zwischen Basisbetrieb, Segmentierung, VPN, DMZ, Layer-7-Kontrolle und Malware-Prüfung. Zusätzlich wird nicht nur der „Happy Path“ beschrieben, sondern auch, an welchen Stellen reale Betriebsprobleme typischerweise entstehen.

8 Fazit

Die dokumentierte Umgebung zeigt eine praktische Infrastrukturarbeit, die deutlich über reine Basisdienste hinausgeht. Sie umfasst:

- Layer-2-Segmentierung mit Trunk-/Access-Design,
- Layer-3-Routing, DNS, DHCP und VPN,
- Layer-4-Dienstpfade, WAN-Uplink und Firewalling,
- Layer-7-DPI, Proxying, TLS-Inspection und Inhaltsprüfung,
- sowie die dazugehörige Betriebs- und Reproduktionsdokumentation.

Als Portfolio-Arbeitsprobe soll diese Dokumentation zeigen, wie ich technische Umgebungen nicht nur aufbaue, sondern auch strukturiert analysiere, absichere, dokumentiere und für andere reproduzierbar beschreibe.